

geoHELP — Riepilogo privacy, trattamento dati e consensi

Destinatario: consulente legale / DPO
Progetto: app mobile **geoHELP** (Android, flavor dev `it.geohelp.dev`)
Versione informativa / consensi in app: `v1` (`ConsentKeys.CURRENT_VERSION`)
Data documento: maggio 2026
Lingue app: italiano (primaria), inglese

Avvertenza: questo documento è una **bozza operativa** redatta sullo stato tecnico dell'applicazione. **Non costituisce consulenza legale.** Serve al legale per redigere informativa definitiva, termini d'uso, registro trattamenti, DPIA e contratti con i responsabili.

Sommario esecutivo

geoHELP consente a utenti registrati di inviare **richieste di aiuto via SMS** con **posizione GPS** e dati di profilo, con opzione **dati medici** e funzione **MAN DOWN** (rilevamento caduta/urto → countdown 60 s → SMS automatici).

Aspetto	Situazione attuale
Titolare del trattamento	[DA COMPILARE] — associazione / società che pubblica il servizio
Hosting dati	Supabase , regione UE (Irlanda)
Dati sanitari	Tabella <code>medical_data</code> , in chiaro su DB, RLS; consenso esplicito art. 9
Consensi in app	3 flag: privacy (obbl.), medical (opz.), man_down (opz.); storico immutabile su <code>consents</code>
Informativa utente	HTML in app (<code>assets/privacy/privacy_v1_it.html</code> / <code>_en.html</code>) + link da schermata consensi
Cancellazione account	[DA DEFINIRE] — procedura non ancora automatizzata in app
Log statistico SMS	Tabella <code>sms_events</code> (senza testo messaggio); base giuridica e retention [DA DEFINIRE col legale]
Telefono utente	Campo obbligatorio <code>profiles.user_phone</code> (+39 E.164); riga Tel. utente negli SMS di emergenza
Fallback SMS MAN DOWN	Se la SIM fallisce: Twilio via Edge Function Supabase <code>send-mandown-sms</code> (mittente <code>geoHELP</code> o numero Twilio in test)
SOS manuale (Help)	Solo app Messaggi / rete operatore — nessun invio tramite Twilio

Parte A — Ruoli GDPR e documentazione da predisporre

A.1 Ruoli

Ruolo	Soggetto tipico	Note per geoHELP
 Titolare del trattamento 	[DA INSERIRE]	Decide finalità e mezzi; responsabile verso gli utenti
 Responsabile del trattamento 	Supabase Inc.	Hosting DB, Auth; richiede DPA firmato
 Sub-responsabili 	Elenco nel DPA Supabase (es. AWS)	Verificare trasferimenti extra-SEE
 Sub-responsabile / fornitore SMS cloud 	Twilio Inc. (USA)	Solo fallback MAN DOWN se SIM fallisce; tratta numeri destinatari, testo SMS, mittente; DPA Twilio e SCC [DA VERIFICARE col legale]
 Destinatari SMS 	Numeri in <code>sos_recipients</code>	Ricevono contenuto SMS, GPS e Tel. utente ; non sono "utenti" dell'app
 Incaricati 	Staff / volontari con accesso dashboard	Policy accessi e formazione
 DPO / RPD 	[DA VALUTARE]	Consigliato valutare obbligo/nomina per dati salute + geoloc. + automazione

A.2 Documenti da far redigere o completare al legale

1. **Informativa privacy** (art. 13–14 GDPR) — espandere HTML v1 in app
2. **Termini e condizioni d’uso** — limitazione responsabilità; non sostituisce 112
3. **Registro dei trattamenti** (art. 30 GDPR)
4. **DPIA / valutazione d’impatto** (art. 35) — dati salute, GPS, MAN DOWN automatizzato
5. **DPA con Supabase** — modulo standard + verifica sub-responsabili
6. **DPA / condizioni Twilio** — per invio SMS cloud (trasferimento verso USA se applicabile)
7. **Policy interna** accessi amministratori e gestione richieste diritti
8. **Procedura cancellazione account** e tempi di risposta

Parte B — Stato tecnico dell’app (per il legale)

B.1 Architettura dati

```
Utente Android (geoHELP)
  → HTTPS → Supabase (UE, Irlanda)
    • auth.users (email, password hash)
    • profiles (nome, anno nascita, email, user_phone, ...)
    • medical_data (patologie, allergie, ...)
    • consents (storico consensi, versione v1)
    • sos_recipients (numeri SOS; gestione admin con flag can_manage_sos_recipients)
    • sms_events (log statistico invii: canale, tipo, emergenza, esito – no testo SMS)
  → Edge Function send-mandown-sms (solo se SIM MAN DOWN fallisce)
    → Twilio Inc. (USA) → SMS ai numeri primari
  → SMS (rete operatore / SIM utente)
```

- SOS manuale (app Messaggi; log «prepared» in sms_events) – no Twilio
- MAN DOWN: prima SIM (SmsManager multipart); se fallisce → Twilio; ultimo fallback Messaggi

B.2 Tabelle database (Supabase public)

Tabella	Contenuto	RLS
profiles	Anagrafica minima + email, user_phone (obbligatorio per SMS)	Solo proprio id
medical_data	Dati sanitari strutturati	Solo proprio user_id
consents	Storico consensi (no update/delete da client)	Solo proprio user_id
sos_recipients	Numeri primari/backup servizio	Select attivi per utenti autenticati/anon
sms_events	Log statistico SMS (vedi § B.5)	Solo proprio user_id (insert/select)

B.3 Funzionalità utente rilevanti per privacy

Funzione	Dati coinvolti	Base giuridica proposta
Registrazione / login	Email, password	Consenso / contratto [legale]
Profilo	Nome, anno nascita, sesso opz., tel. utente (obbl.), tel. familiare opz.	Consenso privacy
SOS manuale	GPS, tipo emergenza, note, nome, Med opz.	Consenso privacy (+ medico se Med in SMS)
Dati medici	Categorie art. 9	Consenso esplicito medical_data
MAN DOWN	Sensori, GPS, SMS auto, eventuale traccia	Consenso man_down
Consensi e privacy	Revoca/aggiornamento, nuova riga DB	Trasparenza + prova consenso
Ricordami	Email/password in EncryptedSharedPreferences	Da dichiarare in informativa
PIN medico	Hash locale per account (non cifra DB)	Lock dispositivo
Log eventi SMS	Metadati in sms_events (no contenuto SMS)	[DA DEFINIRE] — es. legittimo interesse / qualità servizio

B.4 MAN DOWN (dettaglio per DPIA)

1. Rilevamento urto/caduta (accelerometro)
2. Countdown **60 secondi** (annullabile)
3. SMS iniziale ai numeri **primari** (fino a 2 primari + 1 backup, max 3 destinatari)
4. Verifica movimento (~10 s); se movimento → fino a **4 SMS** di tracciamento (ogni 15 s)
5. Invio **multipart** (coordinate, dati medici, riga **Tel. utente: +39...** da user_phone)
6. **Canale invio (ordine):** (a) **SIM** (SmsManager); (b) se fallisce → **Twilio** (send-mandown-sms, mittente geoHELP); (c) se Twilio fallisce → **retry** con rete (Wi-Fi/dati), **senza** apertura app Messaggi
7. Testo SMS in **formato compatto** (meno segmenti a fatturazione); legenda PDF per destinatari SOS: docs/SMS-FORMATO-COMPATTO.pdf

8. Revoca consenso → disarmo servizio

Nota per il legale (Twilio): il testo SMS (inclusi coordinate e tel. utente) transita verso Twilio solo nel ramo (b). Twilio **non** conserva il profilo utente su Supabase; tratta i dati necessari all'invio SMS secondo propria informativa/DPA. Valutare **trasferimento extra-SEE** (USA) e base giuridica (es. consenso MAN DOWN + necessità del soccorso).

B.5 Log statistico SMS (sms_events) — implementato 1.0.50

Finalità proposta (da confermare al legale): statistiche d'uso del servizio, qualità invii, supporto tecnico. **Non** viene salvato il testo degli SMS né coordinate nel log server.

Campo	Significato
channel	manual (SOS da tab Help) · mandown
message_kind	prepared (solo manuale: apertura app Messaggi) · initial · trace · lost_signal
emergency_type	Codice tipo emergenza manuale (incident , illness , vehicle , lost , weather , other) oppure mandown
outcome	ok · failed
Altro	dest_count , segment_count , trace_index (1-4), recipient_role (primary / backup)

Limiti tecnici da dichiarare:

- **SOS manuale:** l'app registra solo l'evento **prepared** (SMS preparato), non l'invio effettivo da parte dell'utente in Messaggi.
- **MAN DOWN:** l'app registra tentativo di invio (ok / failed), non la consegna al destinatario (salvo integrazioni future con callback operatore).

Migrazione DB: supabase/migrations/0010_sms_events.sql

Parte C — I tre consensi in app (testi attuali IT)

C.1 Trattamento dati personali — **OBBLIGATORIO** (privacy)

Label: Trattamento dati personali (obbligatorio)

Testo checkbox (consents_privacy_body):

Acconsento al trattamento dei dati personali (email, nome, anno di nascita, dati opzionali di profilo, posizione GPS al momento dell'invio della richiesta di aiuto) per le finalità del servizio geoHELP, come da informativa privacy. Senza questo consenso non è possibile usare l'app.

Dati inclusi (espansione per informativa):

Dato	Dove
Email	Auth + profiles.email

Dato	Dove
Password	Auth (hash)
Nome, anno nascita, sesso, tel. utente (<code>user_phone</code>), tel. familiare	<code>profiles</code>
GPS, contenuto richiesta	SMS / sensori
Storico consensi	<code>consents</code>
Log eventi SMS (metadati)	<code>sms_events</code>

Revoca: da «Consensi e privacy»; senza privacy l'app non è utilizzabile.

C.2 Dati medici — **OPZIONALE** (`medical_data`)

Label: Dati medici (opzionale)

Testo checkbox (`consents_medical_body`):

Acconsento al salvataggio dei miei dati medici (patologie, allergie, terapie, pacemaker, note) sul backend geoHELP, dove sono conservati in modo strutturato e protetti da regole di sicurezza per utente (RLS) e da trasporto cifrato (HTTPS). Comprendo che i dati possono essere consultati dal team che amministra il servizio per finalità di soccorso, supporto e verifica, e che possono essere inseriti in forma sintetica nelle SMS di emergenza. Sul dispositivo l'accesso al modulo è protetto da un PIN personale. Posso revocare il consenso in qualsiasi momento.

Base giuridica: consenso esplicito art. 9.2.a GDPR.

Trasparenza tecnica: dati **non cifrati** sul server; leggibili da admin autorizzati; PIN solo su dispositivo.

C.3 MAN DOWN — **OPZIONALE** (`man_down`)

Label: Funzione MAN DOWN (caduta / urto) (opzionale)

Testo checkbox (`consents_man_down_body`):

Acconsento all'uso dei sensori di movimento del dispositivo per rilevare possibili cadute o urti violenti e, dopo un conto alla rovescia di 60 secondi annullabile, all'invio automatico di SMS di emergenza ai numeri primari configurati, con posizione GPS e dati essenziali. Comprendo che possono verificarsi falsi allarmi e che l'invio SMS automatico richiede il permesso dedicato sul telefono. Posso disattivare la funzione in qualsiasi momento dall'app.

Nota: utenti con privacy già accettata vedono gate dedicato (`mandown_gate_intro`) se manca storico `man_down` .

Punto per il legale: valutare art. 22 GDPR (decisioni automatizzate).

Parte D — Struttura informativa privacy (indice sezioni §0–§15)

§	Titolo	Contenuto principale	Stato
0	Intestazione	Titolo, invito a leggere, link a consensi	In HTML app
1	Titolare e contatti	Ragione sociale, privacy@, DPO	DA COMPILARE
2	Natura servizio	SOS, MAN DOWN, non sostituisce 112	In HTML app
3	Dati personali	Tabella dati, Supabase UE, SMS, revoca	In HTML app
4	Dati medici	art. 9, RLS, admin, SMS, PIN	In HTML app
5	MAN DOWN	Sensori, 60 s, falsi allarmi, revoca	In HTML app
6	Destinatari / responsabili	Supabase, numeri SOS, team, operatori	DA COMPLETARE
7	Trasferimenti extra-UE	SCC, sub-responsabili Supabase	DA VERIFICARE
8	Conservazione	Tempi per account, medico, consensi, log <code>sms_events</code>	DA DEFINIRE
9	Sicurezza	HTTPS, RLS, PIN; limiti cifratura server	In HTML app
10	Diritti interessato	Accesso, cancellazione, Garante; procedura	DA DEFINIRE
11	Obbligatorietà dati	Email obbl.; med/MAN opz.	In struttura
12	Minori	Età minima / genitori	DA DEFINIRE
13	Modifiche informativa	Versioning v1 → v2 + nuovo consenso	Implementato in app
14	Riepilogo consensi	Tabella 3 <code>consent_type</code>	In app
15	Allegati	Termini, registro, cookie se sito	DA CREARE

File informativa in app: `app/src/main/assets/privacy/privacy_v1_it.html` e `privacy_v1_en.html`

Schermata: `PrivacyPolicyScreen` (WebView), link «Leggi l'informativa privacy completa (v1)»

Disclaimer pre-SMS (aggiornato): cita Supabase UE e invita a leggere informativa; non afferma più assenza di server esterni.

Da aggiungere in informativa (v1 → v2): menzione **Twilio** come fornitore SMS di backup MAN DOWN (solo se SIM fallisce); campo **tel. utente** obbligatorio; tabella `sms_events` (già in struttura §3).

Parte E — Punti da decidere con il legale (checklist)

E.1 Obblighi e valutazioni

- ☐ Nomina **Titolare** e recapiti nel § 1
- ☐ Necessità **DPO**
- ☐ Redazione **DPIA** (salute + geolocalizzazione + automazione MAN DOWN)
- ☐ **Registro trattamenti** art. 30
- ☐ **DPA Supabase** firmato e archiviato
- ☐ **DPA / garanzie Twilio** (SMS cloud, possibile trasferimento USA)

E.2 Contenuti informativa

- ☐ **Tempi di conservazione** (account, medical, consents, `sms_events`)
- ☐ **Base giuridica log** `sms_events` (legittimo interesse / servizio; menzione in § 3 informativa)
- ☐ **Trasferimenti** extra-SEE e garanzie
- ☐ **Telefono utente** (`user_phone` , obbligatorio): finalità, visibilità in SMS, conservazione
- ☐ **Telefono familiare** in profilo: finalità e uso in SMS
- ☐ **Twilio** in § 6 informativa (fallback MAN DOWN, no Help manuale)
- ☐ **Minori** ed età minima servizio
- ☐ **Art. 22** per MAN DOWN
- ☐ **Cancellazione account** (tempi, canale, effetto su DB cascade)

E.3 Documenti aggiuntivi

- ☐ **Termini d'uso**
- ☐ Policy **accesso dashboard** Supabase (chi vede dati medici in chiaro)
- ☐ Istruzioni per **richieste diritti** (email tipo privacy@...)

E.4 Allineamento app

v1.0.42 e precedenti

- ☒ Consenso privacy senza «cognome»
- ☒ Disclaimer SMS allineato a Supabase
- ☒ Link informativa da consensi e pre-SMS
- ☒ Gestione/revoca 3 consensi con storico su server
- ☒ Email su `profiles` + sync da auth

v1.0.50

- ☒ Log statistico `sms_events` (canale manuale / MAN DOWN, tipo emergenza, esito; senza testo SMS)
- ☒ MAN DOWN: SMS multipart (niente troncamento 160 caratteri)
- ☐ Informativa HTML in app: menzione esplicita `sms_events` — **[DA REDIGERE col legale]**

v1.0.55 – v1.0.63

- ☒ `profiles.user_phone` obbligatorio; **T:** in SMS compatto
- ☒ Admin nascosto numeri SOS (PIN + `can_manage_sos_recipients`)
- ☒ Twilio `send-mandown-sms` , mittente `geoHELP` (Messaging Service IT)
- ☒ Fix retry duplicati SMS (1.0.63)

v1.0.64

- ☒ **Formato SMS compatto** unificato (Help SOS, MAN DOWN, traccia, no segnale)
 - ☒ Legenda destinatari: `docs/SMS-FORMATO-COMPATTO.pdf` (uso esterno, non in app)
 - ☒ MAN DOWN: no apertura Messaggi; retry solo con rete
 - ☐ Informativa HTML: Twilio + formato SMS — **[DA REDIGERE col legale]**
-

Parte F — Misure di sicurezza (sintesi tecnica)

Misura	Dettaglio
Trasporto	HTTPS
Accesso DB utente	Row Level Security (solo propri dati)
Auth	Supabase Auth, password non in chiaro
PIN medico	Hash per account su EncryptedSharedPreferences
Ricordami	Email/password cifrate localmente (opzionale)
SMS MAN DOWN	SIM → Twilio (geoHELP) → retry rete; formato compatto; Help solo Messaggi/SIM
Log SMS server	sms_events , RLS; nessun testo messaggio
Secret Twilio	Solo Supabase Edge Functions Secrets, non nell'app
Admin	Service role non nel client mobile; gestione SOS con PIN in app dev

Rischio residuo da dichiarare: team admin può leggere `medical_data` in chiaro per soccorso/supporto (come da consenso).

Parte G — Diritti dell’interessato (bozza operativa)

Diritto	Come l’utente può esercitarlo oggi	Gap
Accesso / rettifica	Modifica profilo; dati medici in app	Export strutturato [opzionale]
Revoca consenso	«Consensi e privacy»	OK
Cancellazione	[DA IMPLEMENTARE] richiesta a [email]	Procedura manuale possibile interim
Portabilità	[DA DEFINIRE]	
Reclamo Garante	www.garanteprivacy.it	Citare in informativa

Parte H — Versioning e modifiche future

- Ogni consenso salvato con `version = v1` e timestamp `accepted_at` .
- Modifica sostanziale informativa → `v2` + nuova accettazione in `ConsentsScreen` .
- Storico `consents` **immutabile** (solo insert).

Appendice — Riferimenti file progetto

File	Descrizione
docs/informativa-privacy-struttura-v1.md	Struttura dettagliata §0–§15
app/src/main/assets/privacy/privacy_v1_*.html	Informativa mostrata in app
supabase/schema.sql	Schema DB e RLS

File	Descrizione
supabase/migrations/0010_sms_events.sql	Tabella log SMS
supabase/migrations/0011_sos_recipients_admin_manage.sql	Flag admin SOS
supabase/migrations/0012_profiles_user_phone.sql	Tel. utente obbligatorio
supabase/functions/send-mandown-sms/	Edge Function Twilio
docs/TWILIO-SETUP.md	Setup e test Twilio / telefono
docs/SMS-FORMATO-COMPATTO.md / .pdf	Legenda SMS compatto per team SOS
app/.../mandown/ManDownTwilioRepository.kt	Client fallback Twilio
app/.../ConsentsRepository.kt	Logica consensi
app/.../data/sms/SmsEventsRepository.kt	Scrittura log SMS
app/.../strings.xml	Testi UI consensi (IT)

Fine documento — bozza per revisione legale.